

Fix What Matters to Your Business

Summary of Vulnerabilities & Threats

12–18 September 2022

The second week of September 2022 witnessed the discovery of 657 vulnerabilities out of which 44 gained the attention of Threat Actors and security researchers worldwide. Among these 44, five were zero-days, and five vulnerabilities are awaiting analysis on the National Vulnerability Database (NVD). Hive Pro Threat Research Team has curated a list of 44 CVEs that require immediate action.

This week, Uber experienced a mission-critical security breach following a social engineering attack on an employee that forced the company to shut down its internal communications and engineering systems.

Parallely, Monti ransomware targeted the VMware Horizon virtualization system by exploiting the well-known "Log4Shell" vulnerability. Further, Iranian government-sponsored threat actors launched attacks using Fortinet, Microsoft Exchange, Log4j, and VMware Horizon vulnerabilities.

Further, we also observed two Threat Actor groups being highly active in the last week. First was a quadruple actor gang comprised of DEV-0842, DEV-0861, DEV-0166, and DEV-0133 of Iranian provenance, which was targeting Albanian government websites for financial gain. The second was SparklingGoblin, a Chinese threat actor known for information theft and espionage, who was spotted advancing the SideWalk backdoor. Common TTPs which could potentially be exploited by these threat actors or CVEs can be found in the detailed section.

Published Vulnerabilities	Interesting Vulnerabilities	Active Threat Groups	Targeted Countries	Targeted Industries	ATT&CK TTPs
657	44	2	40	18	48

Detailed Report

⚙ Interesting Vulnerabilities

VENDOR	CVE	PATCH DETAILS
	CVE-2022-32917* CVE-2022-32894* CVE-2022-32902 CVE-2022-32854 CVE-2022-32896 CVE-2022-32911 CVE-2022-32864 CVE-2022-32883 CVE-2022-32908 CVE-2022-32900	Upgrade to macOS Big Sur 11.7 and macOS Monterey 12.6
	CVE-2022-37969* CVE-2022-34718 CVE-2022-34721 CVE-2022-34722 CVE-2022-35805 CVE-2022-34700 CVE-2022-37957 CVE-2022-35803 CVE-2022-37954 CVE-2022-34725 CVE-2022-34729 CVE-2022-34729 CVE-2019-0604 CVE-2021-26855 CVE-2021-34473 CVE-2021-34523 CVE-2021-31207 CVE-2021-31196 CVE-2021-31206 CVE-2021-33768 CVE-2021-33766 CVE-2021-34470	https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-37969 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-34718 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-34721 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-34722 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-35805 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-34700 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-37957 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-35803 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-37954 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-34725 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-34729 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2019-0604 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-26855 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-34473 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-34523 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-31207 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-31196 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-31206 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-33768 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-33766 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-34470

* zero-day vulnerability

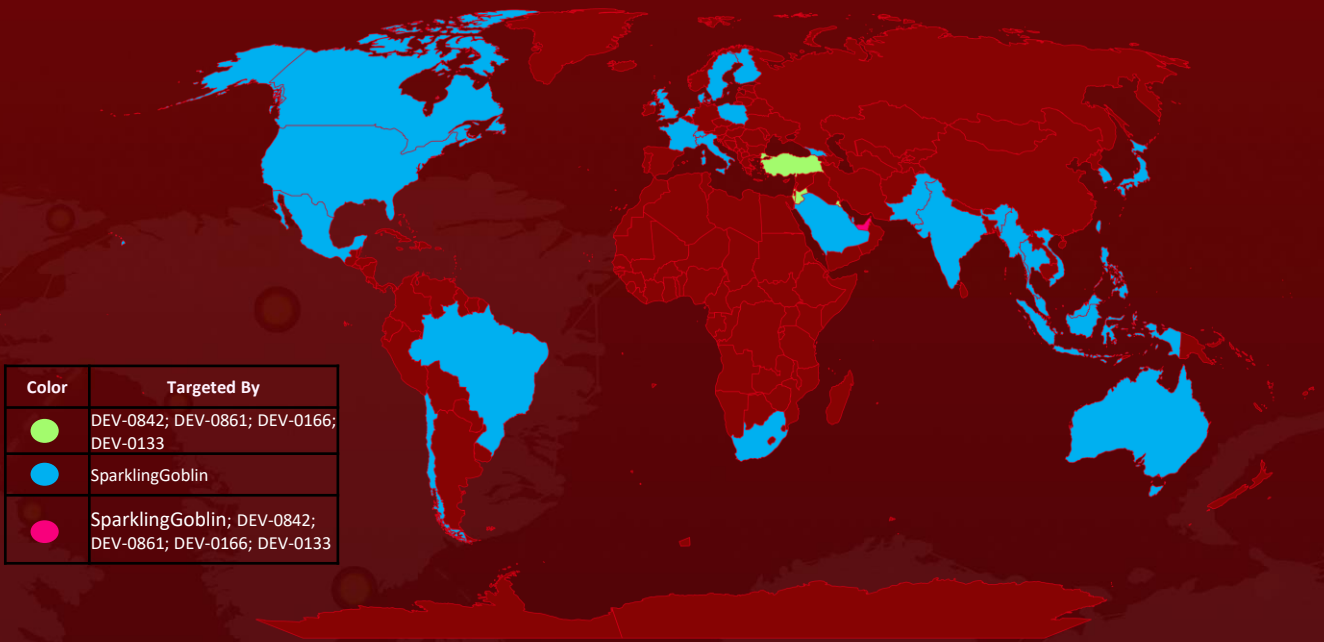
VENDOR	CVE	PATCH DETAILS
	CVE-2022-31474*	https://ithemes.com/blog/wordpress-vulnerability-report-special-edition-september-6-2022-backupbuddy/
	CVE-2021-44228 CVE-2021-45046 CVE-2021-45105	https://www.vmware.com/security/advisories/VMSA-2021-0028.html
	CVE-2018-13379 CVE-2020-12812 CVE-2019-5591	https://www.fortiguard.com/psirt/FG-IR-18-384 https://www.fortiguard.com/psirt/FG-IR-19-283 https://www.fortiguard.com/psirt/FG-IR-19-037
	CVE-2022-40139* CVE-2022-40140 CVE-2022-40141 CVE-2022-40142 CVE-2022-40143 CVE-2022-40144	https://files.trendmicro.com/products/Apex%20One/apexone_sp1_win_en_gm_b11092.exe

* zero-day vulnerability

Active Actors

ICON	NAME	ORIGIN	MOTIVE
	DEV-0842	Iran	Financial gain, Information theft and Espionage
	DEV-0861	Iran	Financial gain, Information theft and Espionage
	DEV-0166	Iran	Financial gain, Information theft and Espionage
	DEV-0133	Iran	Financial gain, Information theft and Espionage
	SparklingGoblin (APT 41, Double Dragon, TG-2633, Bronze Atlas, Red Kelpie, Blackfly, Earth Baku, Grayfly)	China	Financial crime, Information theft and Espionage

Targeted Locations



Powered by Bing
© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom

Targeted Industries



Common MITRE ATT&CK TTPs

TA0043: Reconnaissance	TA0042: Resource Development	TA0001: Initial Access	TA0002: Execution	TA0003: Persistence	TA0004: Privilege Escalation	TA0005: Defense Evasion
T1592: Gather Victim Host Information	T1588: Obtain Capabilities	T1189: Drive-by Compromise	T1203: Exploitation for Client Execution	T1574: Hijack Execution Flow	T1574: Hijack Execution Flow	T1574: Hijack Execution Flow
T1589: Gather Victim Identity Information	T1588.001: Malware	T1190: Exploit Public-Facing Application	T1059: Command and Scripting Interpreter	T1546: Event Triggered Execution	T1548: Abuse Elevation Control Mechanism	T1548: Abuse Elevation Control Mechanism
	T1588.006: Vulnerabilities		T1059.001: PowerShell	T1543: Create or Modify System Process	T1546: Event Triggered Execution	T1140: Deobfuscate/Decode Files or Information
	T1588.002: Tool		T1053: Scheduled Task/Job	T1547: Boot or Logon Autostart Execution	T1068: Exploitation for Privilege Escalation	T1553: Subvert Trust Controls
	T1587: Develop Capabilities		T1053.005: Scheduled Task	T1505: Server Software Component	T1547: Boot or Logon Autostart Execution	T1553.002: Code Signing
	T1587.001: Malware			T1053: Scheduled Task/Job	T1055: Process Injection	T1036: Masquerading
				T1053.005: Scheduled Task	T1053: Scheduled Task/Job	T1036.001: Invalid Code Signature
				T1136: Create Account	T1053.005: Scheduled Task	T1055: Process Injection
				T1136.001: Local Account		
				T1136.002: Domain Account		

TA0006: Credential Access	TA0007: Discovery	TA0008: Lateral Movement	TA0009: Collection	TA0011: Command and Control	TA0040: Impact
T1555: Credentials from Password Stores	T1016: System Network Configuration Discovery	T1210: Exploitation of Remote Services	T1560: Archive Collected Data	T1071: Application Layer Protocol	T1485: Data Destruction
			T1560.001: Archive via Utility	T1071.001: Web Protocols	T1565: Data Manipulation
				T1573: Encrypted Channel	T1565.001: Stored Data Manipulation
				T1573.001: Symmetric Cryptography	T1496: Resource Hijacking
					T1486: Data Encrypted for Impact
					T1499: Endpoint Denial of Service

Threat Advisories

<https://www.hivepro.com/two-zero-day-vulnerabilities-in-macos-bigsur/>

<https://www.hivepro.com/zero-day-vulnerability-in-the-wordpress-backupbuddy-plugin/>

<https://www.hivepro.com/microsoft-busts-an-actively-exploited-zero-day-and-several-critical-flaws/>

<https://www.hivepro.com/monti-ransomware-infiltrates-networks-via-the-well-known-log4shell/>

<https://www.hivepro.com/multiple-iranian-actors-have-launched-attacks-against-the-albanian-government/>

<https://www.hivepro.com/unknown-iranian-attackers-leverage-vulnerabilities-to-conduct-ransom-operations/>

<https://www.hivepro.com/sparklinggoblin-revamps-sidewalk-backdoor-for-linux-variant/>

<https://www.hivepro.com/zero-day-vulnerability-uncovered-in-trend-micro-apex-one/>

What Next?

Book a free demo with **HivePro Uni5** to check your exposure to this advisory. HivePro Uni5 is a Continuous Threat Exposure Management Solution that proactively reduces an organization's attack surface before it gets exploited.



At Hive Pro we take a long hard look at your vulnerabilities so you can bolster your defenses and fine-tune your offensive cybersecurity tactics.

REPORT GENERATED ON

September 19, 2022 • 3:10 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com